How to harden Windows 11 with the CIS Benchmark

A phased, fact-checked playbook for Windows 11 hardening: CIS Level 1 vs Level 2, how CIS relates to Microsoft security baselines, Intune vs Group Policy vs LGPO, pilot rings, the controls that matter (Credential Guard, LSA protection, ASR, BitLocker, SMB signing, legacy protocols, logging), exceptions, compliance scanning and keeping up with new benchmark versions.

12 phases | 38 steps | Tick each item when its "done when" criterion is true

Phase 1 Understand CIS and pick your baseline about 1–3 days

- [ ] **1.1 Get the right benchmark and version**
  Current CIS Windows 11 benchmark PDF downloaded from cisecurity.org; version noted in your hardening standard
- [ ] **1.2 Choose Level 1, Level 2 and the add-on profiles**
  Profile decided per device group (for example L1 + BitLocker for everyone, L2 for admin workstations)
- [ ] **1.3 Decide: CIS Benchmark, Microsoft security baseline, or both**
  Written decision on the primary baseline and how gaps against the other are handled

Phase 2 Choose your deployment tooling about 2–5 days

- [ ] **2.1 Intune-managed devices: security baselines, settings catalog and endpoint security**
  Baseline profile, settings catalog policies and endpoint security policies mapped to the benchmark sections they cover
- [ ] **2.2 Domain-joined devices: Group Policy with SCT or CIS Build Kits**
  Hardening GPOs built from SCT baseline or CIS Build Kit; Policy Analyzer comparison saved
- [ ] **2.3 Standalone and lab machines: LGPO**
  LGPO.exe workflow documented for non-managed devices and test VMs
- [ ] **2.4 Prevent policy conflicts between tools**
  Each benchmark section has exactly one owning tool and policy; conflicts report is empty in pilot

Phase 3 Plan a phased rollout about 1 week to plan, 4–8 weeks to roll out

- [ ] **3.1 Measure where you are before you change anything**
  Baseline scan of a representative device per hardware/OS model saved as 'before'
- [ ] **3.2 Use audit modes wherever Windows offers them**
  ASR rules, LSA protection, NTLM, SMBv1 and device control run in audit before enforcement
- [ ] **3.3 Roll out in rings**
  Rings defined (lab → IT → representative pilot → broad) with entry and exit criteria

Phase 4 Accounts, credentials and local policies about 1–2 weeks

- [ ] **4.1 Set account lockout and password policy deliberately**
  Lockout threshold, duration and reset counter set per your chosen profile; trade-off documented
- [ ] **4.2 Review user rights assignments and security options**
  User rights and security options compared with the benchmark; every deviation in the exceptions register
- [ ] **4.3 Manage the local administrator with Windows LAPS**
  Windows LAPS policy deployed; every device has a unique, rotating local admin password
- [ ] **4.4 Turn on Credential Guard and memory integrity (VBS)**
  Win32_DeviceGuard shows Credential Guard and memory integrity running on pilot devices
- [ ] **4.5 Run LSASS as a protected process (LSA protection)**
  WinInit event 12 shows LSASS started as a protected process; no 3033/3063 blocks for required plug-ins

Phase 5 Antivirus, ASR rules and app control about 2–4 weeks (incl. audit period)

- [ ] **5.1 Lock in Defender Antivirus: cloud protection, tamper protection, PUA**
  Cloud protection on, tamper protection on, PUA blocking on; settings match the CIS Defender Antivirus benchmark

- [ ] **5.2 Deploy attack surface reduction rules: audit, exclude, block**
  All ASR rules in Audit for the pilot; standard protection rules in Block; others moved to Block or Warn with documented exclusions
- [ ] **5.3 Turn on SmartScreen everywhere and stop users clicking through**
  SmartScreen on for Windows and Edge; Edge PreventSmartScreenPromptOverride enabled
- [ ] **5.4 Plan application control and PowerShell Constrained Language Mode**
  Decision recorded on App Control for Business / AppLocker; CLM only planned together with it

Phase 6 Encryption and removable media about 1–3 weeks

- [ ] **6.1 Enforce BitLocker with recovery keys escrowed**
  Encryption report shows all devices encrypted; recovery keys in Entra ID; rotation enabled
- [ ] **6.2 Control removable storage**
  Removable storage policy in audit, then enforced; exceptions by device ID for approved hardware

Phase 7 Firewall, SMB and legacy protocols about 2–4 weeks

- [ ] **7.1 Keep Windows Firewall on for every profile**
  Firewall on for Domain, Private and Public; inbound default block; local rule merge decided
- [ ] **7.2 SMB: keep SMBv1 off and signing on**
  SMBv1 absent on all clients; SMB signing required; NAS and printers that can't sign replaced or updated
- [ ] **7.3 Retire NTLM step by step**
  NTLM audit enabled; NTLM users identified; NTLMv1 gone; restrictions planned per server
- [ ] **7.4 Turn off LLMNR and limit NetBIOS name resolution**
  LLMNR disabled by policy; NetBIOS name resolution limited where your build supports it
- [ ] **7.5 Remove legacy components**
  No dependency on PowerShell 2.0, WMIC, SMBv1, TLS 1.0/1.1 or VBScript in your app inventory

Phase 8 Audit policy and logging about 1–2 weeks

- [ ] **8.1 Configure advanced audit policy**
  Advanced audit subcategories set per benchmark; command line in process creation events enabled
- [ ] **8.2 Turn on PowerShell script block logging**
  Script block logging on for Windows PowerShell 5.1 (and PowerShell 7 if installed); event 4104 collected

Phase 9 Remote access and the browser about 1 week

- [ ] **9.1 Harden Remote Desktop, or turn it off**
  RDP disabled where not needed; where needed: NLA, no saved passwords, password prompt, no drive redirection
- [ ] **9.2 Apply a browser baseline for Edge**
  Edge security baseline (Intune or SCT) deployed; SmartScreen enforced; CIS Edge benchmark gaps reviewed

Phase 10 Breakages and exceptions about Ongoing (set up in ~2 days)

- [ ] **10.1 Know the usual breakages before users find them**
  Known-breakage list shared with the service desk before each ring
- [ ] **10.2 Document every exception**
  Exceptions register with setting, reason, compensating control, owner, scope group and expiry date

Phase 11 Measure compliance about Set up in ~1 week, then monthly

- [ ] **11.1 Scan with CIS-CAT**
  CIS-CAT report for each device model; score tracked over time
- [ ] **11.2 Use Intune reporting for policy health**
  Baseline per-setting status reviewed monthly; no settings in Conflict or Error
- [ ] **11.3 Continuous CIS assessment with Defender Vulnerability Management**
  DVM baseline profile for Windows 11 against CIS at your chosen level; exceptions added; monthly review
- [ ] **11.4 Track Secure Score for the device recommendations**
  Secure Score device recommendations reviewed monthly alongside the CIS score

Phase 12 Maintain: new benchmark and baseline versions about Per release (~1–2 weeks each)

- [ ] **12.1 Watch for new versions**
  CIS WorkBench newsletter on; Microsoft deprecated-features RSS followed; owner named for baseline updates
- [ ] **12.2 Diff, re-pilot and re-review exceptions**
  Changelog reviewed; differences applied to ring 1 first; exceptions re-approved or closed

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft, CIS or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.github.io/guides/windows-11-cis-hardening.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.